

Nombre: Pedro Esteban Cotoc sacayon.

Bypass de Autenticación: Entendí que cuando el formulario de inicio de sesión concatena texto directamente, un atacante puede usar la comilla simple (') para romper la estructura original de la consulta. Al ingresar un payload como admin' #, el símbolo de numeral (#) actúa como un comentario en MySQL, obligando al servidor a ignorar la validación del password y otorgando acceso inmediato.

Ataques con UNION: Aprendí a extraer registros de otras tablas combinando la consulta original con sentencias maliciosas a través del operador UNION. Para que este ataque tenga éxito, descubrí que es obligatorio cumplir con dos reglas en el motor SQL: la query inyectada debe devolver exactamente el mismo número de columnas que la legítima y los tipos de datos entre ellas deben ser totalmente compatibles.

Inyección ExtractValue: Validé el peligro de que una aplicación muestre alertas internas del motor de datos. Utilizando la técnica ExtractValue, forcé intencionalmente un fallo de parseo XML al pasarle un ID inválido. El resultado es que MySQL aborta la ejecución pero expone la información confidencial filtrada directamente dentro del mensaje de error visible.

Inyección Ciega Booleana: Esta técnica se aplica cuando el sitio no refleja errores ni datos en la interfaz. Como la plataforma solo reacciona de manera visual dependiendo de si la consulta es verdadera o falsa, aprendí a realizar inferencias lógicas binarias.

UPDATE: Confirmé que la inyección SQL no se limita a la lectura de datos. Si un campo editable por el usuario se concatena en una sentencia de escritura, es posible alterar filas ajenas. Al romper la query e inyectar campos adicionales, logré simular una escalada de privilegios, modificando columnas críticas en la tabla de usuarios, como cambiar el rol de acceso a 'administrador'.

